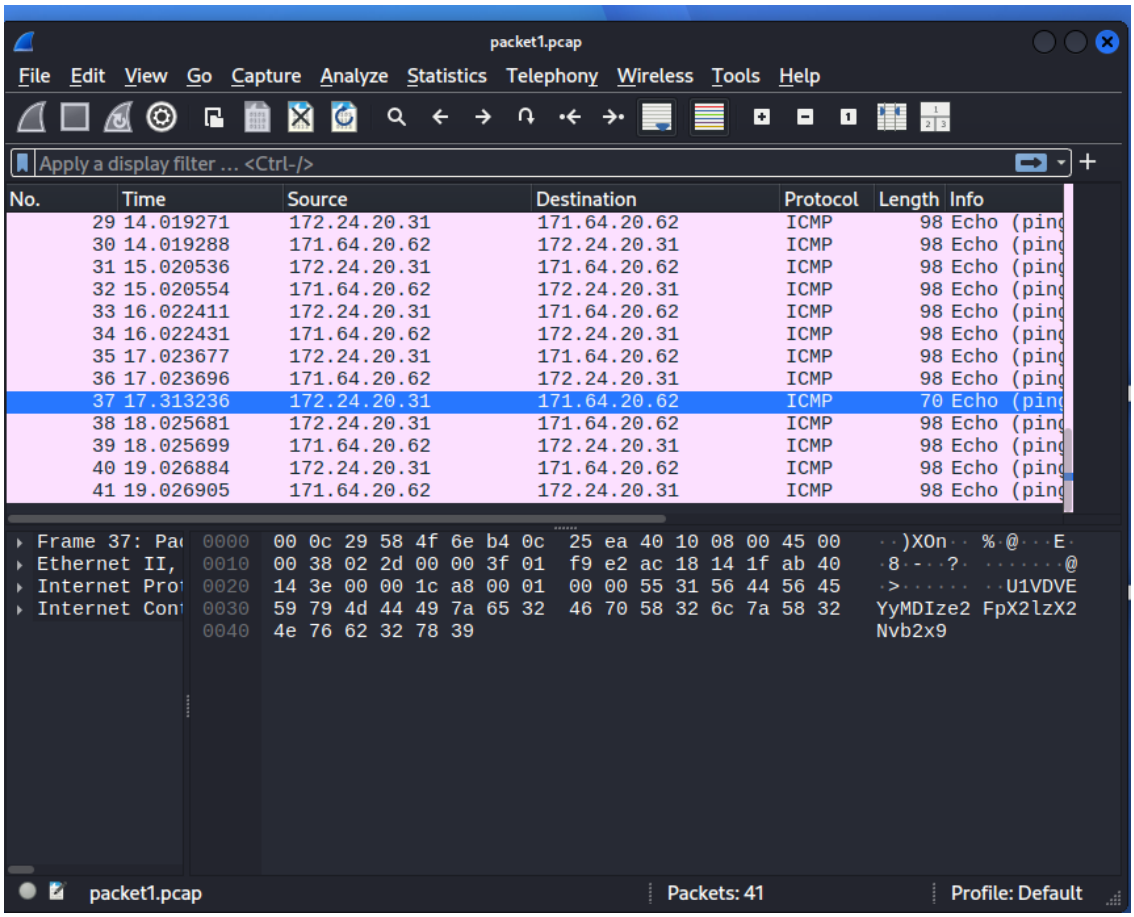
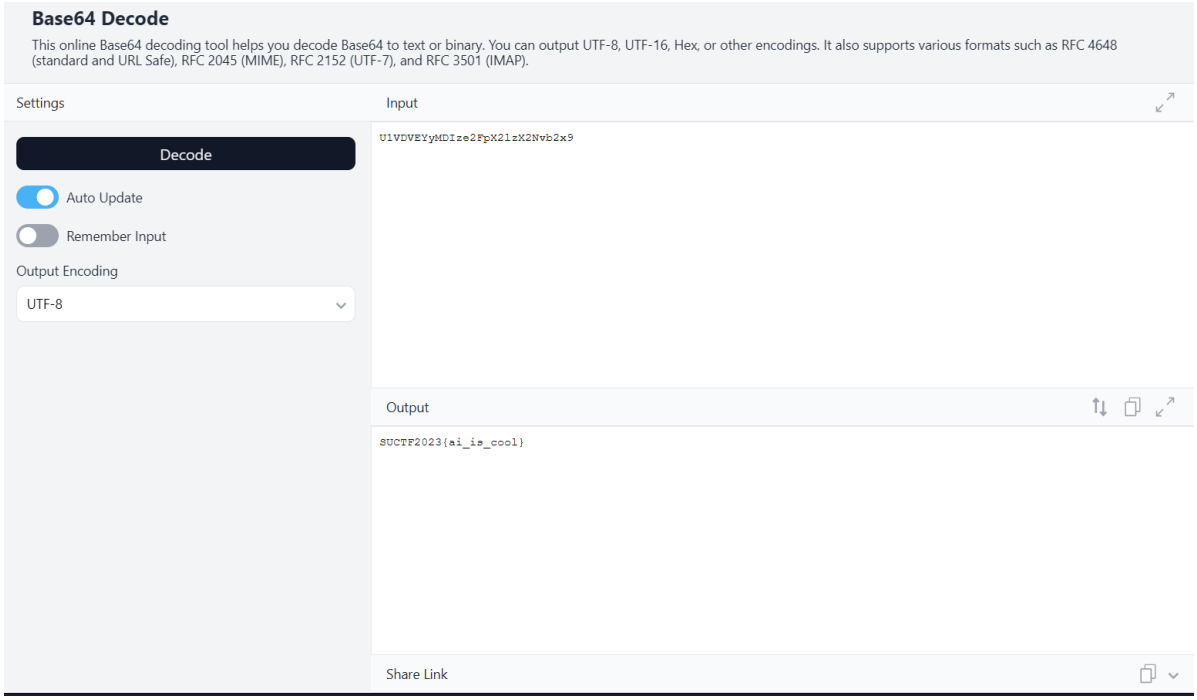
SUBJECT	VULNERABILITY ANALYSIS
CODE	IKB21004 & IKB21403
TASK	FILE ANALYSIS – SCANNING RESULT

Question 1: Analyse packet1.pcap and find the flag.

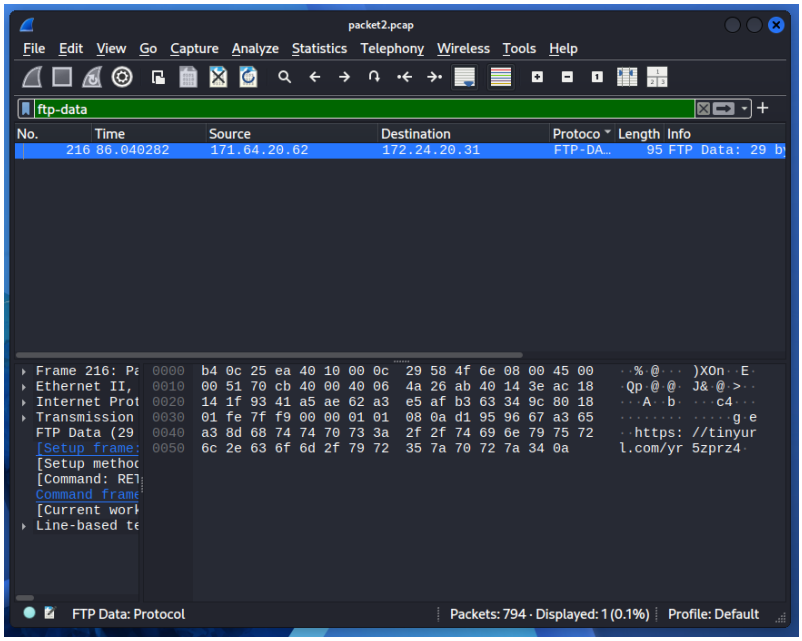
- Upon inspecting all packets, I have found only this specific one to contain ASCII encoded data. The ASCII encoded data is “U1VDVEYyMDIze2 FpX2lzX2Nvb2x9”. After decoding it using a Base68 decoder, I found that the flag reads “SUCTF2023{ai_is_cool}”

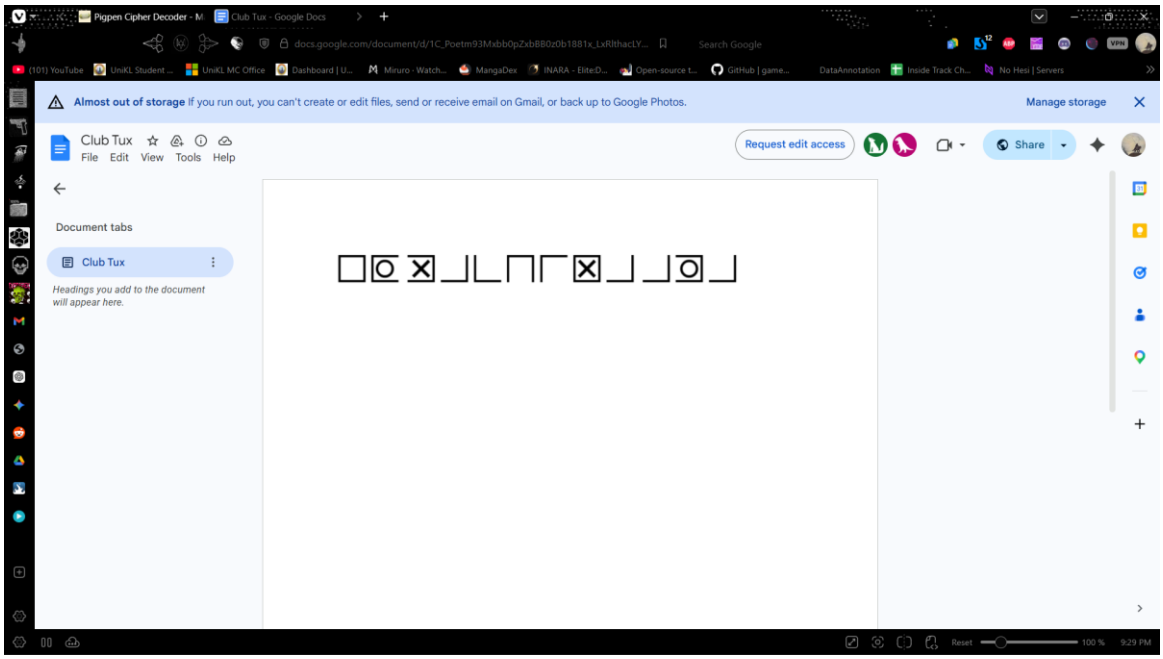




Question 2: Analyse packet2.pcap and find the flag.

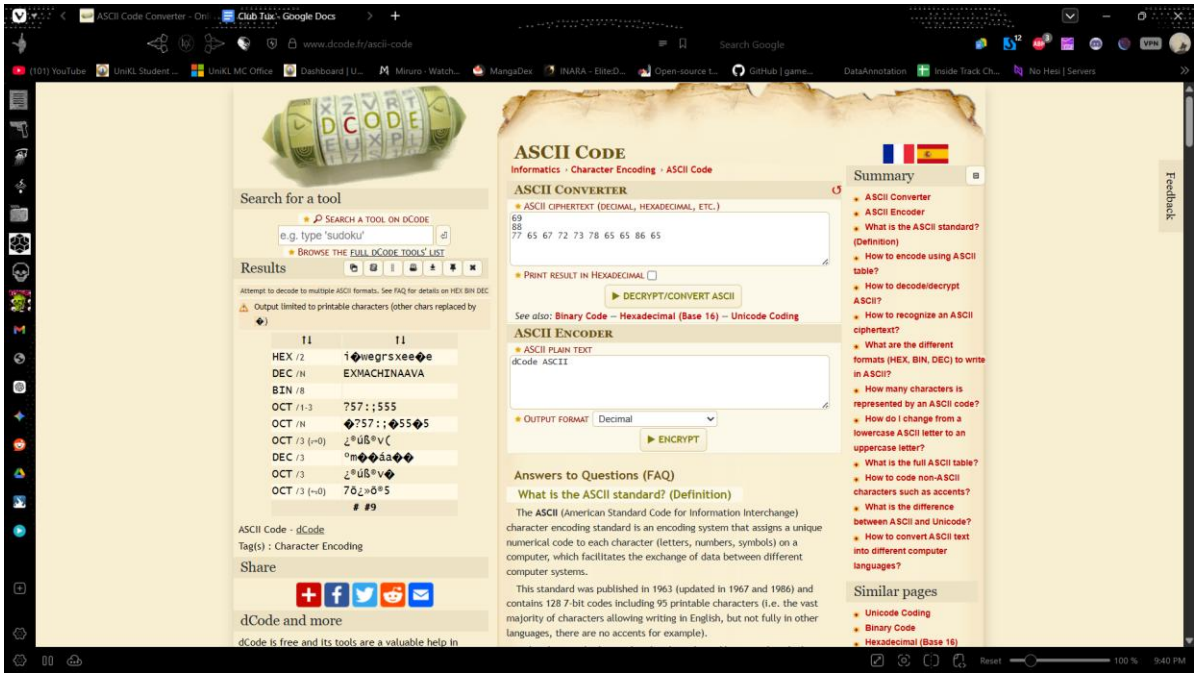
- Using Wireshark to analyze the packet, I found a series of interactions between 2 parties (or devices) related to a global thermonuclear war. After sorting the packets by FTP protocol, I found that the last packet contains a tinyurl link, which directed me to a Google Doc. The doc is titled Club Tux and it contains pigpen cipher. I used the site dcode.fr to decipher the contents of the doc and found that the results read “EX MACHINA AVA”. I then downloaded the doc as a .txt file and ran the cat command in my Kali terminal, which then displays multiple chars and numbers. Once again, I used dcoder.fr to decode them as ASCII code and the results read as: “EXHMACHINAAVA”.




Club Tux - Google Docs
Almost out of storage If you run out, you can't create or edit files, send or receive email on Gmail, or back up to Google Photos.
Manage storage
Club Tux
File Edit View Tools Help
Request edit access
Share
Document tabs
Club Tux
Headings you add to the document will appear here.

Pigpen Cipher Decoder
www.dcode.fr/pigpen-cipher
Search for a tool
Results
#N: Variants (see FAQ)
#0 EX MACHINA AVA
#1 EX MACHINA AUA
#2 EX QACHIRA AMA
#3 RK ZNPUVAN NIN
#6 IV HAEOQJA AWA
#5 IV HAEOQJA AYA
#7 E- OACHIPA A-A
#4 MF UIKPQVI IDI
#8 J- GBFPRIB B-B
Pigpen Cipher - dCode
Tag(s) : Symbol Substitution
Share
dCode and more
PIGPEN CIPHER
Cryptography › Substitution Cipher › Symbol Substitution › Pigpen Cipher
PIGPEN DECODER
DECRYPT
See also: Templars Cipher – Rosicrucian Cipher – Dada Urka Cipher
PIGPEN ENCODER
dCode PigPen
ENCRYPT
See also: Templars Cipher – Rosicrucian Cipher
Answers to Questions (FAQ)
What is the PigPen cipher? (Definition)
The Pig Pen Cipher, also known as the Freemason Cipher (or masonic alphabet), is an encryption system that was historically used by some
Summary
PigPen Decoder
PigPen Encoder
What is the PigPen cipher? (Definition)
How to encrypt using PigPen cipher?
How to decrypt using PigPen cipher?
How to recognize PigPen ciphertext?
What are the variants of the Freemason's PigPen cipher?
Why was Pig Pen cipher created?
Why this cipher is named Pig Pen?
When PigPen was invented?
Similar pages
Rosicrucian Cipher
Templars Cipher
Symbols Cipher List
Dada Urka Cipher
Elian Script
Betamaze Cipher
Nyctography Lewis Carroll
DCODE'S TOOLS LIST
Support dCode
Feedback

kali@kali: /media/sf_sharewithKali
Session Actions Edit View Help
(kali㉿kali)-[/media/sf_sharewithKali]
$ cat Club\ Tux.txt
char(69)
char(88)
char(77) char(65) char(67) char(72) char(73) char(78) char(65) char(65) char(86) char(65)
(kali㉿kali)-[/media/sf_sharewithKali]
$


ASCII Code Converter - Onl
Club Tux - Google Docs
www.dcode.fr/ascii-code
Search Google
(101) YouTube
UniKL Student ...
UniKL MC Office
Dashboard | U...
Miruro · Watch...
MangaDex
INARA - EliteD...
Open-source t...
GitHub | game...
DataAnnotation
Inside Track Ch...
No Hesi | Servers
Search for a tool
Search a tool on dCode
e.g. type 'sudoku'
Browse the full dCode tools' list
Results
Attempt to decode to multiple ASCII formats. See FAQ for details on HEX BIN DEC
Output limited to printable characters (other chars replaced by ◆)
HEX /2 i◆wegrsxee◆e
DEC /N EXMACHINAAVA
BIN /8
OCT /1-3 ?57::555
OCT /N ◆?57::◆55◆5
OCT /3 (=0) ¿®úß®v(
DEC /3 °m◆◆áa◆◆
OCT /3 ¿®úß®v◆
OCT /3 (=0) 7ó¿»ó®5
#9
ASCII Code - dCode
Tag(s) : Character Encoding
Share
dCode and more
dCode is free and its tools are a valuable help in
ASCII Code
Informatics › Character Encoding › ASCII Code
ASCII Converter
ASCII ciphertext (decimal, hexadecimal, etc.)
69
88
77 65 67 72 73 78 65 65 86 65
Print result in hexadecimal
DECRYPT/CONVERT ASCII
See also: Binary Code – Hexadecimal (Base 16) – Unicode Coding
ASCII Encoder
ASCII plain text
dCode ASCII
Output format Decimal
ENCRYPT
Answers to Questions (FAQ)
What is the ASCII standard? (Definition)
The ASCII (American Standard Code for Information Interchange) character encoding standard is an encoding system that assigns a unique numerical code to each character (letters, numbers, symbols) on a computer, which facilitates the exchange of data between different computer systems.
This standard was published in 1963 (updated in 1967 and 1986) and contains 128 7-bit codes including 95 printable characters (i.e. the vast majority of characters allowing writing in English, but not fully in other languages, there are no accents for example).
Summary
ASCII Converter
ASCII Encoder
What is the ASCII standard? (Definition)
How to encode using ASCII table?
How to decode/decrypt ASCII?
How to recognize an ASCII ciphertext?
What are the different formats (HEX, BIN, DEC) to write in ASCII?
How many characters is represented by an ASCII code?
How do I change from a lowercase ASCII letter to an uppercase letter?
What is the full ASCII table?
How to code non-ASCII characters such as accents?
What is the difference between ASCII and Unicode?
How to convert ASCII text into different computer languages?
Similar pages
Unicode Coding
Binary Code
Hexadecimal (Base 16)
Feedback
Reset
100 %
9:40 PM

Question 3: Interpret an Nmap Output

PORT STATE SERVICE VERSION
21/tcp open ftp vsftpd 2.3.4
22/tcp open ssh OpenSSH 5.3p1
80/tcp open hBp Apache 2.2.8
139/tcp open netbios-ssn
445/tcp open microsoft-ds Windows 7 Professional 7601 Service Pack 1

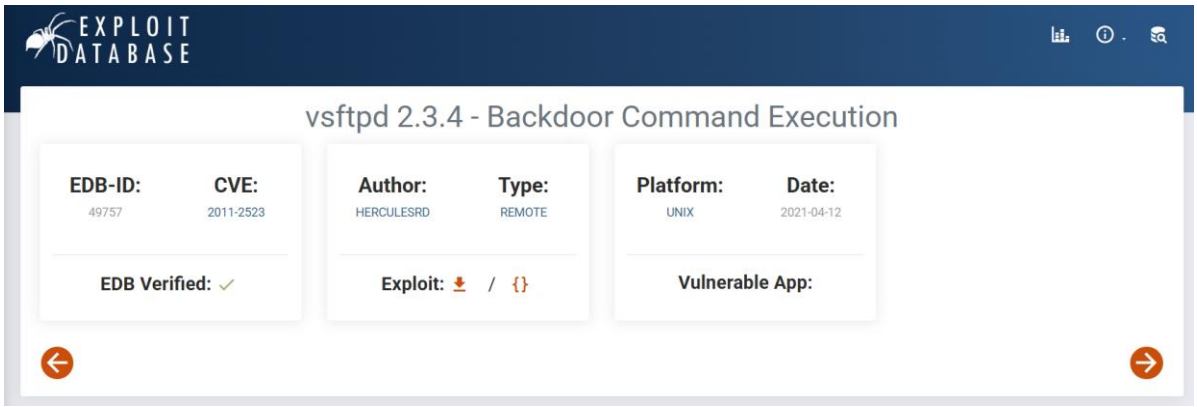
Questions:

1. What can an attacker do with each port?

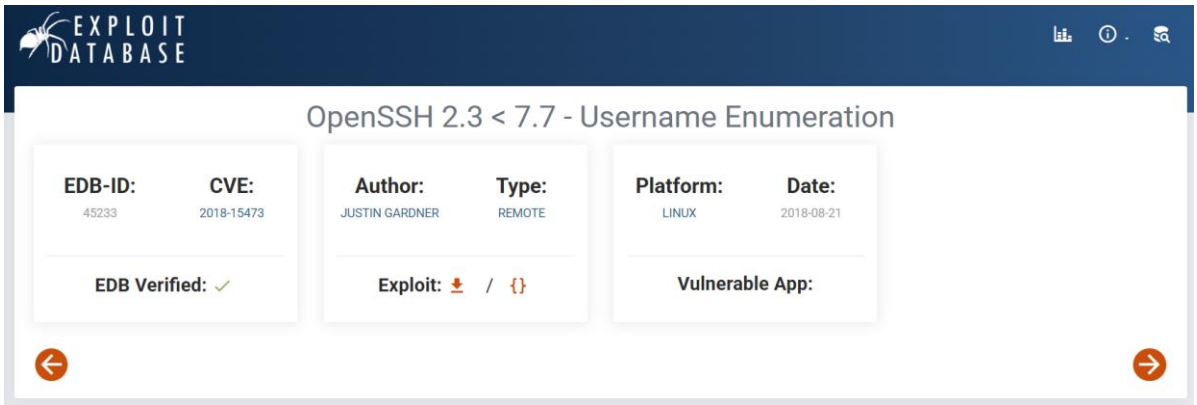
Port	**Service**	**Potential Attacker Actions**
21	Vsftpd 2.3.4	- Brute-force Attacks - Anonymous login - RCE
22	OpenSSH 5.3p1	- Credential stuffing - Brute-force attacks - Gain shell access
80	Apache 2.2.8	- Probe for webapp vulnerabilities - SQL injection
139	Netbios-ssn	- Perform enumeration of network shares, users, domains - Man-in-the-Middle attacks
445	SMB Microsoft-DS	- Exploit legacy SMB (EternalBlue) - Privilege escalation - Unauthorized file access

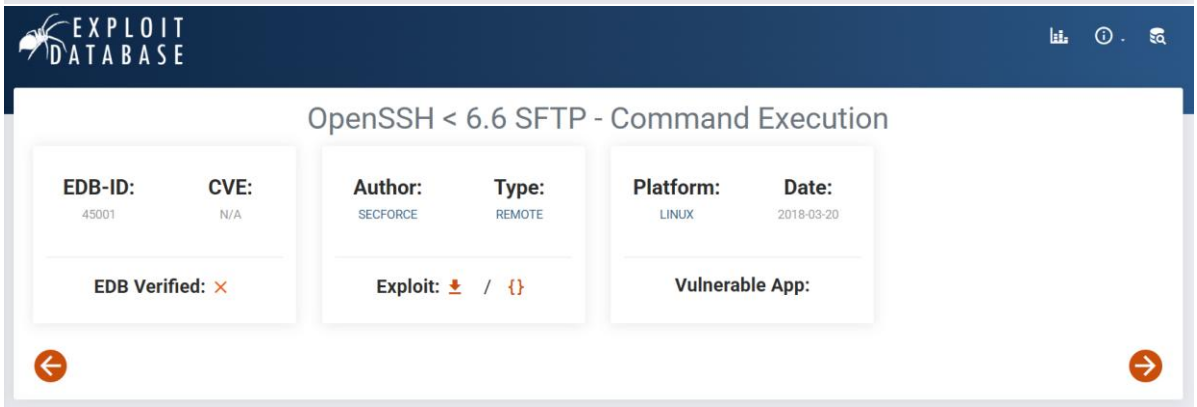
2. What vulnerabilities are likely present based on the version?

- **Vsftpd 2.3.4**



- **OpenSSH 5.3p1**





- **Apache 2.2.8**

Description

According to its banner, the version of Apache 2.2.x running on the remote host is prior to 2.2.8. It is, therefore, affected by the following vulnerabilities :

- A cross-site scripting issue involving mod_imagemap (CVE-2007-5000).

- A cross-site scripting issue involving 413 error pages via a malformed HTTP method (PR 44014 / CVE-2007-6203).

- A cross-site scripting issue in mod_status involving the refresh parameter (CVE-2007-6388).

- A cross-site scripting issue in mod_proxy_balancer involving the worker route and worker redirect string of the balancer manager (CVE-2007-6421).

- A denial of service issue in the balancer_handler function in mod_proxy_balancer can be triggered by an authenticated user when a threaded Multi- Processing Module is used (CVE-2007-6422).

- A cross-site scripting issue using UTF-7 encoding in mod_proxy_ftp exists because it does not define a charset (CVE-2008-0005).

- **Netbios-ssn**

Port 139 – NetBIOS Session Service

Service: netbios-ssn

Protocol: TCP

Port: 139

Used for: File and printer sharing in Windows networks (SMB over NetBIOS)

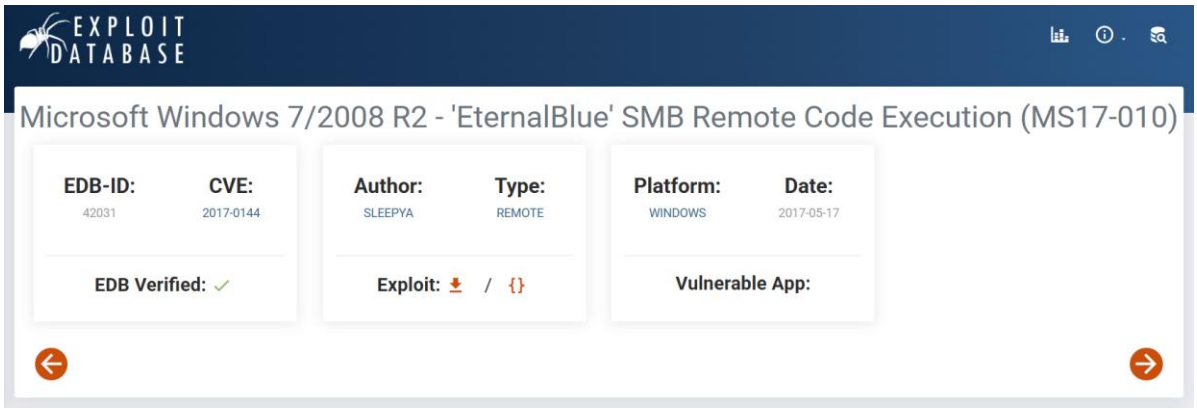
Why It's Open

Port 139/TCP is the NetBIOS Session Service — the transport SMB used before Microsoft added direct SMB-over-TCP on port 445. It's still open on most modern Windows systems because the NetBIOS over TCP/IP stack is enabled by default and on older domains that haven't been migrated. Seeing 139 and 445 together is the classic Windows fingerprint.

Common Risks

- **SMBv1 legacy exploits.** EternalBlue (MS17-010), MS08-067, and related remote code execution bugs. SMBv1 should not exist on a modern network.
- **NULL session enumeration.** Older Windows accepts unauthenticated sessions that leak users, groups, shares, and password policy.
- **Credential relaying.** NTLM responses captured from port 139 can be relayed to other hosts still accepting NTLM authentication.
- **Share misconfiguration.** World-writable or world-readable shares are still common in the wild, especially on file servers and NAS devices.
- **Lateral movement.** Any foothold in a Windows network makes 139/445 the primary lateral-movement target.

- **SMB Microsoft-DS**



3. Which one is the highest risk and why?

- Port 445 (SMB) because it exposes an outdated, unsupported Windows 7 operating system. Exploits like EternalBlue are automated, highly stable and provide SYSTEM-level (full administrative) access to the machine, often allowing for lateral movement across a network.

4. What attack path can be built from this?

- **Reconnaissance:** Identify the target via Nmap (as shown).
- **Exploitation:** Use an automated exploit tool (e.g., Metasploit) to target the SMB service on port 445 to gain a reverse shell with system privileges.
- **Persistence/Escalation:** Install a persistent backdoor or perform credential dumping (e.g., Mimikatz) to harvest password hashes.
- **Lateral Movement:** Use the gathered credentials to access other machines in the network, leveraging the open ports (22, 21, 139) to jump to other hosts.

5. What should be the remediation?

- FTP (21)

- Upgrade vsftpd
- Disable anonymous login

- SSH (22)

- Use stronger passwords
- Enable key-based authentication

- HTTP (80)

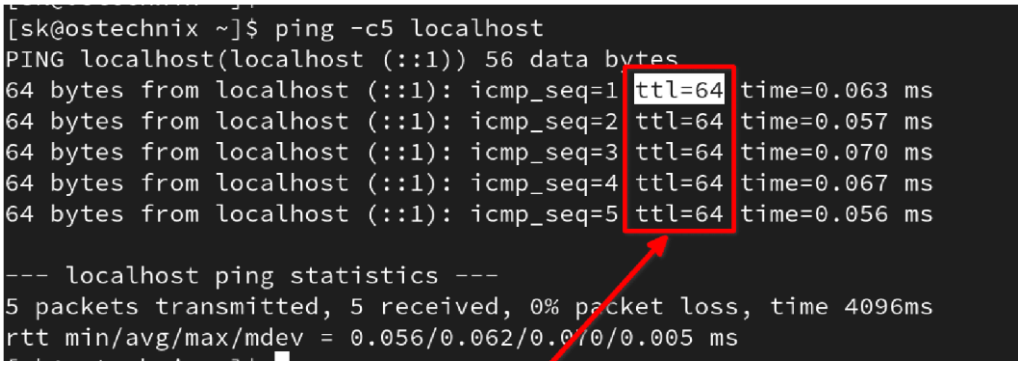
- Update Apache
- Apply web security patches

- NetBIOS (139)
- Disable if not needed

- SMB (445)
- Patch MS17-010
- Disable SMBv1
- Upgrade from Windows 7

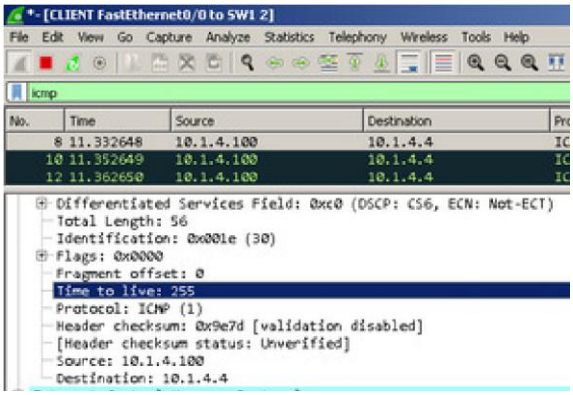
Question 4: Identify the OS (OS Fingerprinting) - TTL

Image 1



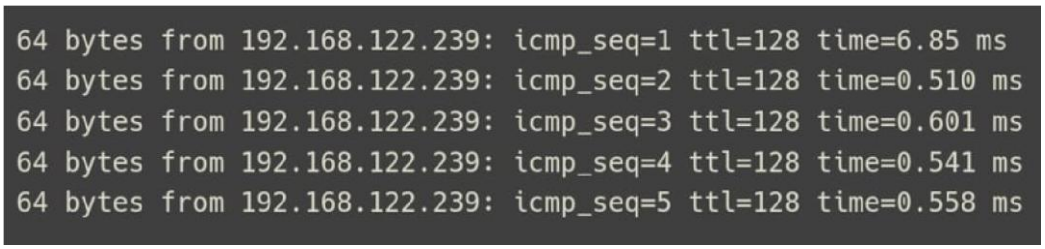
Answer: Linux (64)

Image 2



Answer: Cisco / Network Devices (Routers, Switches, Firewalls)

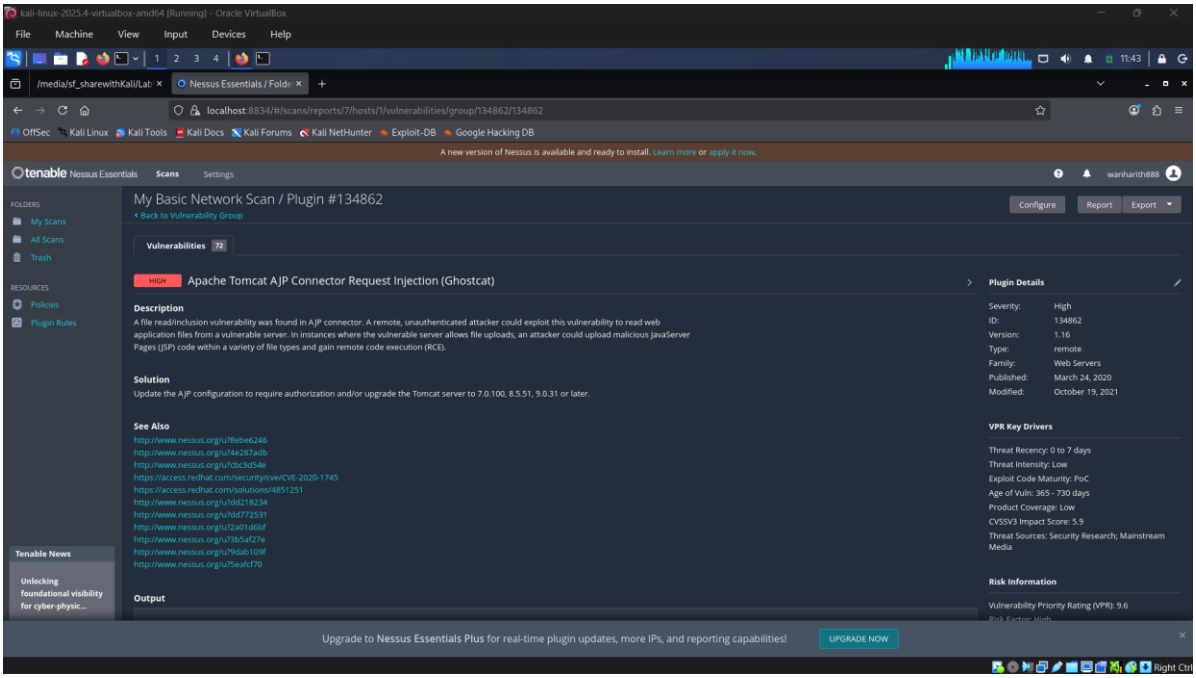
Image 3:



Answer: Windows OS

Question 5: Analyse the Nessus file

Upload to your nessus (Network_Scan.nessus) and analyse the files. Focus on critical or high findings that was identifies in analysis named “Ghostcat”.



1. What is the affected Port number

- 8009

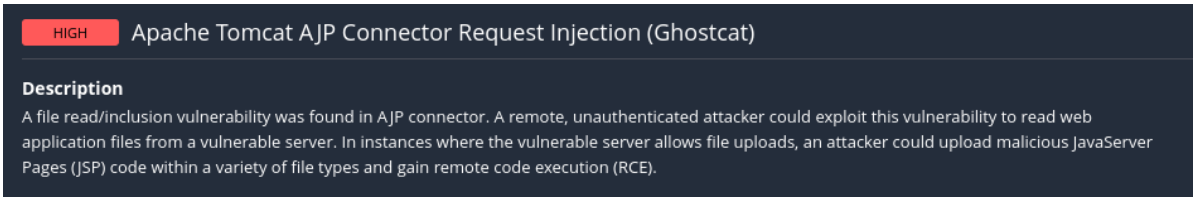
2. What is the Affected protocol

- ajp13

3. What is the CVSS Score of vulnerability found?

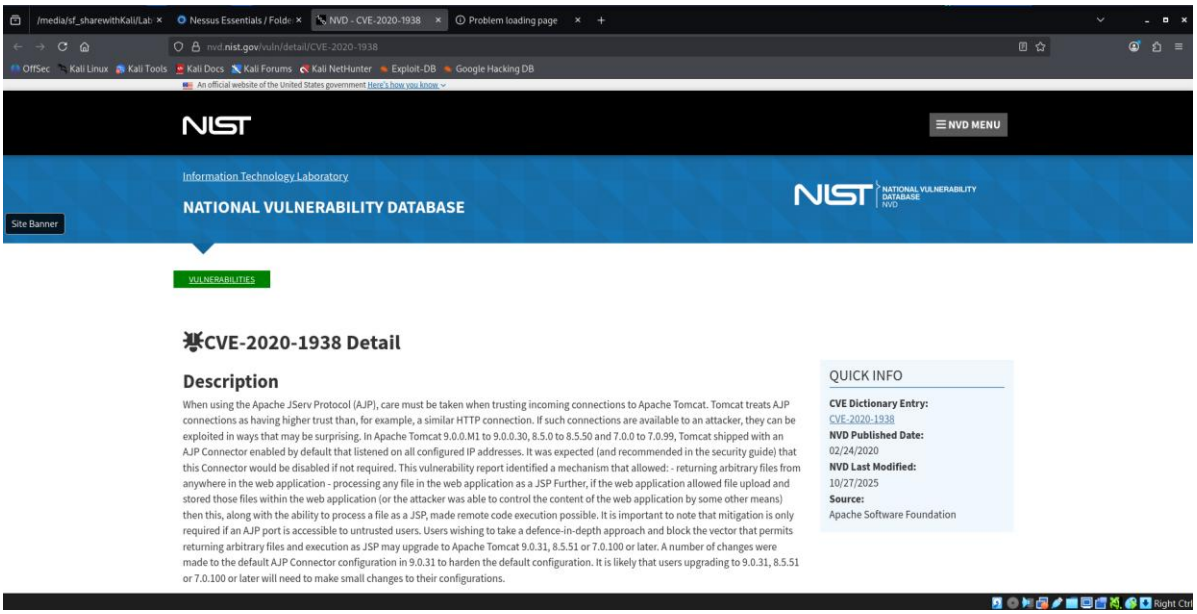
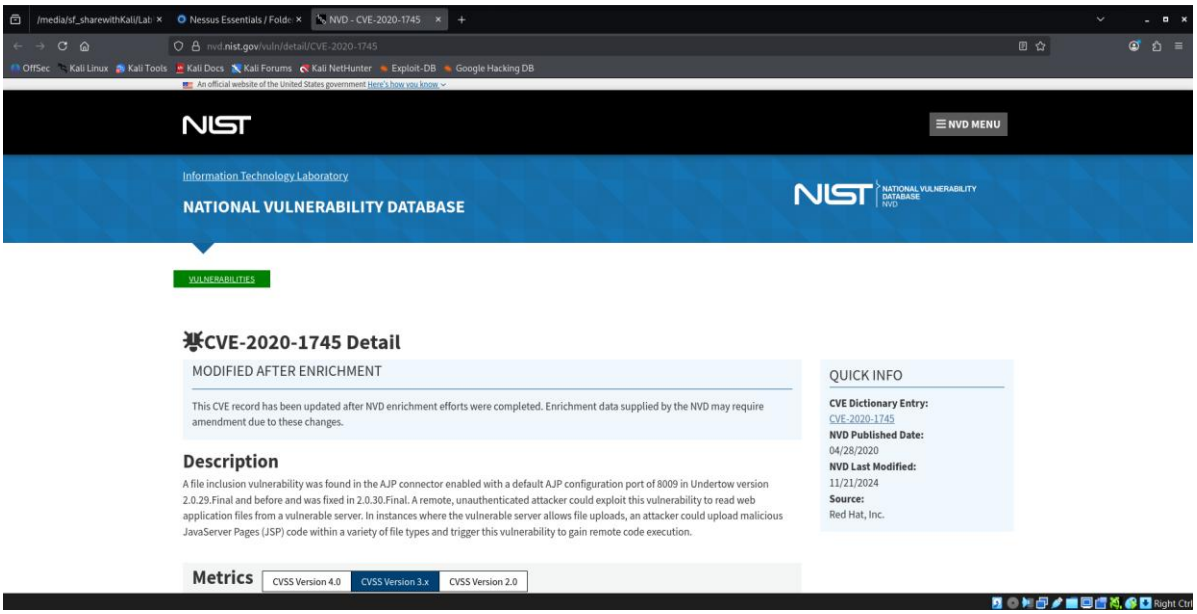
- 9.8 (HIGH)

4. Can you find any exploit related to this vulnerability?

- 

5. Find CVE for this vulnerability.

- CVE-2020-1938



- CVE-2020-1745